

Data Classification Framework

Complete framework with classification levels, labeling guidelines, handling rules and Sri Lankan examples

Document ID	FRM-DC-001
Version	1.0 (template)
Classification	Internal
Owner	[Data Protection Officer / IT Security Manager]
Approved by	[Name, Title]
Effective date	[DD Month YYYY]
Next review	[DD Month YYYY — review at least annually]

Customization required

This template is a starting point published by the OpenDLP-LK community. Replace all bracketed placeholders, adapt the content to your organization's size, industry and risk profile, and obtain legal review before adoption. Aligned with Sri Lanka's Personal Data Protection Act (PDPA) No. 9 of 2022.

<https://opendlp-lk.github.io> • Licensed under MIT — free to use, adapt and redistribute.

1. Purpose

This framework establishes how [Organization Name] categorizes data according to sensitivity and business impact, so that protection, handling and DLP enforcement are proportionate to risk. Consistent classification is the foundation of every DLP rule: content that carries a classification label (or matches a classified data pattern) drives blocking, encryption and alerting decisions.

2. Classification Levels

Level	Definition	Impact of unauthorized disclosure
RESTRICTED	Highly sensitive data whose disclosure could cause severe damage to the organization or individuals.	Severe: regulatory penalties, identity theft, major financial/reputational loss.
CONFIDENTIAL	Sensitive business or personal data intended for limited, named audiences.	Serious: competitive harm, contractual breach, harm to individuals.
INTERNAL	Routine business data intended for staff use only.	Limited: embarrassment or minor operational impact.
PUBLIC	Information approved for public release.	None: already intended for disclosure.

Sri Lankan examples per level

Level	Examples
RESTRICTED	NIC numbers (old 9+V/X and new 12-digit formats), passport numbers, driving license numbers, bank account and card numbers, health records, biometric data, authentication credentials, special-category personal data under the PDPA.
CONFIDENTIAL	Employee records and salaries, customer lists with contact details, contracts, unpublished financials, strategic plans, source code, vendor pricing.
INTERNAL	Internal memos, SOPs, organizational charts, meeting minutes, project schedules, internal telephone directory.
PUBLIC	Marketing brochures, published annual reports, press releases, public website content, job advertisements.

3. Protection Requirements by Level

Control	RESTRICTED	CONFIDENTIAL	INTERNAL	PUBLIC
Encryption at rest	AES-256 mandatory	Required on portable devices	Recommended	Not required
Encryption in transit	TLS 1.2+ mandatory	TLS 1.2+ mandatory	TLS recommended	Not required
Access control	Named individuals + MFA	Role-based (RBAC)	All staff	Unrestricted

External sharing	Prohibited without DPO approval	Requires manager approval + secure channel	Not for public distribution	Permitted
DLP action on egress	Block + alert	Warn/justify + alert	Log only	None
Printing	Secure-release printing only	Collect immediately; shred after use	Standard care	Unrestricted
Retention & disposal	Per retention schedule; certified destruction	Per retention schedule; secure deletion	Routine disposal	Routine disposal
Access logging	Full audit trail, reviewed monthly	Logged, reviewed quarterly	Basic logging	None

4. Labeling Guidelines

- Documents: include the classification in the header or footer of every page, e.g. “CONFIDENTIAL — [Organization Name]”. Templates should default to Internal.
- Email: prefix the subject line with the label for Confidential and Restricted messages, e.g. “[RESTRICTED] Q3 payroll file”, and/or apply sensitivity labels in Microsoft 365 / Google Workspace.
- Files and folders: apply metadata labels via the document management or sensitivity-labeling tool so DLP can read them; where unavailable, use folder naming conventions.
- Databases: record classification at column level in the data inventory (e.g. customers.nic_number = RESTRICTED) to drive masking and access rules.
- Physical media: mark printed documents, USB drives and backup tapes with visible classification stickers.

5. Classification Decision Guide

Ask in order; classify at the first “yes”:

- ! Does it contain identifiers usable for identity theft or fraud (NIC, passport, financial, health, biometric, credentials) or special-category personal data? ! RESTRICTED
- ! Could disclosure harm the organization, a client or an individual (contracts, personnel data, unpublished financials)? ! CONFIDENTIAL
- ! Is it meant only for staff, without external audience? ! INTERNAL
- ! Has it been approved for public release by [Communications]? ! PUBLIC

Default rule

If in doubt, classify one level higher and consult the data owner. Aggregated data inherits the level of its most sensitive element — a spreadsheet of 10,000 rows containing one NIC column is RESTRICTED.

6. Roles and Responsibilities

Role	Responsibility
Data owners	Assign classification at creation; review at least annually; approve reclassification and external sharing.

Data custodians (IT)	Implement technical controls matching each level; configure DLP policies keyed to labels and patterns.
All personnel	Label new documents; handle data per its level; report misclassified or exposed data.
DPO	Maintain data inventory; audit classification compliance; align framework with PDPA obligations.

7. Reclassification and Declassification

Data may change sensitivity over time (e.g. financial results become Public after publication). Reclassification requires data owner approval and an inventory update. Declassification of Restricted data additionally requires DPO approval. Review classifications during the annual data inventory refresh.